

Response to Reviewers
Manuscript ID DATA-00033-2026
*Descriptor: AEGIS Threat Matrix for Agentic AI Systems
(ATX-1)*

Kenneth Tannenbaum
AEGIS Initiative, AEGIS Operations LLC
ktannenbaum@aegis-initiative.com — ORCID 0009-0007-4215-1789

2026-05-20

Editorial Note

We thank the Editor-in-Chief, the Associate Editor, and both Reviewers for the careful and constructive feedback on the original submission. The revisions described below address every concern raised in the decision letter, and we believe substantially strengthen the manuscript.

Two structural updates inform the revision as a whole:

1. **Dataset version update.** As cleared by the Editor-in-Chief (Prof. Stephen Makonin) in email correspondence dated 2026-04-24, the descriptor is updated to reflect ATX-1 v2.3 (released 2026-04-24; Zenodo DOI [10.5281/zenodo.20171712](https://doi.org/10.5281/zenodo.20171712)) rather than the v1.0 baseline reviewed by the original referees. v2.3 removes the `severity` field in alignment with MITRE ATT&CK and ATLAS conventions; this version bump simultaneously resolves Reviewer 1’s methodology concern (R1-1) and Associate Editor concern AE-1. All numerical claims and figures are updated accordingly. v1.0 remains frozen at its original IEEE DataPort DOI (10.21227/f87b-1d57) for reproducibility of the reviewed record.
2. **Post-submission corroborating evidence.** As cleared by the Editor-in-Chief in the same correspondence, several empirical studies that were published after the original submission (2026-03-26) but bear directly on Reviewer 2’s empirical-base concern are now folded into the revised manuscript. Specifically: Anthropic’s *Agentic Misalignment* study (Lynch et al., June 2025), the Microsoft AI Red Team’s *Taxonomy of Failure Modes in Agentic AI Systems* (April 2025), Cemri et al.’s *Why Do Multi-Agent LLM Systems Fail?* (NeurIPS 2025), and others.

The revised manuscript is submitted with tracked changes marked via the LaTeX `changes` package (blue underline for additions, red strikethrough for deletions). The remainder of this document responds point-by-point to each comment.

Editor-in-Chief Comments

E-1. “Remove super-script TM from your article title.”

Response. Done.

Action. The `\texttrademark{}` markup is removed from the title via tracked-changes deletion. The change is visible in the revised manuscript title and in the `\markboth` line (which never carried the mark).

Associate Editor Comments

AE-1. Severity ratings rely on subjective judgment and lack quantitative validation.

Reviewer’s concern. “The proposed taxonomy and severity ratings rely largely on subjective judgment and lack quantitative or empirical validation.”

Response. Concur. ATX-1 v2.3 removes the `severity` field from technique definitions entirely. The rationale, articulated in the revised manuscript, follows the MITRE ATT&CK and ATLAS convention: severity is appropriately a deployment-context attribute (function of asset, environment, and controls present), not a fixed taxonomy property. Embedding it in the taxonomy forced every consumer to either trust the author’s judgment or override it. Removing it frees consumers to apply their own scoring frameworks (CVSS, OWASP Risk Rating, organizational risk models) per environment, exactly as ATT&CK and ATLAS do.

Action.

- Removed `severity` from all 58 entries in `atx-1-techniques.json`.
- Removed `severity` from `atx-technique.schema.json` (required array and `properties` block).
- Updated the Technique Record Structure table (Table 1) to remove the `severity` row and add `parent_technique` / `sub_techniques` fields.
- Updated Figure 2 caption to drop the “color-coded by severity” reference.
- Replaced the *Severity Distribution* subsection with a new *Severity Removed in v2.3* subsection that explains the rationale.
- Updated Limitations to remove the prior severity-rating caveat; replaced with a forward note on consumer-side severity attachment.
- The schema-version bump (2.2 → 2.3) is recorded in `atx-1-version-mapping.json`.

AE-2. Dataset construction process is not sufficiently detailed to ensure reproducibility.

Reviewer’s concern. “The dataset construction process is not sufficiently detailed to ensure reproducibility, particularly regarding how cases are mapped to techniques and tactics.”

Response. Concur. The original manuscript described the four-stage construction process at a high level but did not document the decision rules at each stage. The revision adds a new subsection that makes these rules explicit.

Action. A new *Construction Reproducibility* subsection is added inside §COLLECTION METHODS AND DESIGN, between *Taxonomy Construction* and Table 1. It documents:

- **Case-to-root-cause coding rules** for RC1–RC5, each with an explicit condition under which the code applies.
- **Case-to-technique abstraction criteria.** Failure modes are divided into separate techniques when (i) mechanism, (ii) mitigation, or (iii) threat surface differs. Multiple cases collapse into a single technique when all three align.
- **Sub-technique introduction rules.** A sub-technique (v2.2+ format T####.###) is created when a specific bypass method is sufficiently distinct in mechanism AND cannot be addressed by the parent’s mitigation alone.
- **Tactic-boundary rules.** Three-factor priority: agent’s effective goal, architectural layer affected, dominant mitigation pattern.
- **End-to-end processing flow.** Inputs → outputs for each of the four stages, with explicit reference to the dataset fields (`agents_of_chaos_case`, `root_cause`, etc.) that preserve traceability.

The complete pipeline is published in `atx-1-techniques.json` (records) and `atx-1-version-mapping.json` (per-version derivation provenance), supporting independent verification.

AE-3. Validation focuses on structural correctness; semantic correctness is insufficiently supported.

Reviewer’s concern. “The current validation focuses mainly on structural correctness (e.g., STIX compliance), while the semantic correctness and completeness of the taxonomy remain insufficiently supported.”

Response. Concur. Structural correctness (schema validation, STIX compliance, cross-reference completeness) was the only validation in v1.0. Semantic correctness—that the taxonomy’s tactics and techniques correspond to real failure modes observable beyond the original dataset—is now established by three additional lines of evidence.

Action. A new *External Validation and Corroborating Evidence* subsection is added inside §VALIDATION AND QUALITY (after *Cross-Reference Completeness*, before *Severity Removed in v2.3*). It establishes:

1. **Controlled multi-agent evaluation (Round 1).** A 2026-04-08 replication of the *Agents of Chaos* environment with an added governance condition. Six agents matching the AoC roster were deployed; in the ungoverned phase the agents reproduced every AoC failure class covered by the infrastructure (identity spoofing, credential compromise, reply-loop DoS, autonomous offensive-tool generation, self-modification). Eight of the ten v2.3 tactic categories were empirically observed. The exercise is documented in a separate Zenodo deposit ([10.5281/zenodo.20159697](https://zenodo.org/record/20159697)) and cited as [16] in the revised bibliography.
2. **Corroborating-studies coverage.** Each of the ten v2.3 tactics is independently observed in at least three studies outside the original AoC dataset. The new subsection cites the Microsoft AI Red Team taxonomy [17], Anthropic’s *Agentic Misalignment* study [18], Cemri et al.’s MAST taxonomy [19], MITRE ATLAS v5.4.0 agentic techniques [3], AgentHarm [20], AgentDojo [21], InjecAgent [22], OpenAgentSafety [23], HAICosystem [24], Alignment Faking [25], In-Context Scheming [26], and Greshake et al.’s foundational indirect-prompt-injection paper [27].
3. **Production-incident corroboration.** Five documented production incidents are cited: *EchoLeak* (CVE-2025-32711, Aim Labs) [28], *Reprompt* (CVE-2025-64671, Varonis Threat Labs) [33], the *Replit Production-Database Deletion* incident [29], *Microsoft Semantic Kernel RCE* (CVE-2026-26030 and CVE-2026-25592, Microsoft Defender) [34], and *IDEsaster* (twenty-four CVEs across ten AI coding assistants including Cursor, GitHub Copilot, Claude Code, Windsurf, Kiro, Zed, Roo Code, JetBrains Junie, Cline, and Gemini CLI) [35]. The Microsoft Semantic Kernel disclosure is particularly relevant because it directly validates the v2.1 TA010 thesis that governance abstractions cannot model the execution environment’s full capabilities; IDEsaster corroborates T10003 (Inject Persistent Agent Instructions) with the same RFC-0006 plugin-injection class we cite as the technique’s origin.

In addition, two research benchmarks not in the original submission are now cited: *Breaking Agents* (Zhang et al., 2024) [31], which demonstrated that autonomous agents can be induced into malfunction loops with failure rates exceeding 80% in multi-agent scenarios (corroborating TA006/TA009); and *CVE-Bench* (Zhu et al., ICML 2025) [32], which evaluated frontier AI agents against 40 real-world web-application CVEs and reported state-of-the-art agents resolving approximately 13% of the critical vulnerabilities, establishing a measurable baseline for autonomous offensive capability that motivates the TA002/TA003 framing.

The cumulative empirical base now includes approximately thirty frontier-lab incidents, 200+ hand-coded multi-agent failure traces (Cemri MAST), 350+ OpenAgentSafety scenarios, the Breaking Agents malfunction-amplification benchmark, the CVE-Bench autonomous-exploitation benchmark, fourteen new MITRE ATLAS agentic techniques, a parallel Microsoft Red Team taxonomy, five documented production incidents, and the Round 1 controlled replication.

AE-4. Dataset appears derived from limited sources; generalization is a concern.

Reviewer’s concern. “The dataset appears to be derived from limited sources, raising concerns about generalization and coverage.”

Response. This concern is addressed by the same actions as AE-3. The v1.0 manuscript reflected an 11-case-study empirical base; the v2.3 revision reflects an empirical base of approximately 30 frontier-lab incidents, 200+ MAST traces, 350+ OpenAgentSafety scenarios, plus production incidents and a sister-framework taxonomy.

Action. Bibliography expanded from 15 to 35 entries (20 new). The Limitations subsection is rewritten to reflect the cumulative evidence base rather than the v1.0 single-source posture. The taxonomy is no longer reasonably characterized as “derived from limited sources.”

AE-5. “Agentic AI” and “governance boundary” should be more rigorously defined.

Reviewer’s concern. “Key concepts such as ‘agentic AI’ and ‘governance boundary’ should be more rigorously defined.”

Response. Concur. The original manuscript used both terms in narrative form without formal definitions.

Action. A new *Definitions* subsection is added at the end of §BACKGROUND, before Figure 2. It provides formal definitions for:

- **Agentic AI.** A system in which an LLM (or other AI mechanism) produces actions that execute against operational infrastructure without per-action human authorization. The distinction is the action layer: text/recommendations are not agentic; tool calls against systems, APIs, or files are.
- **Governance boundary.** The architectural point at which an agent’s proposed actions are evaluated against policy. Structurally distinct from training-time alignment (RLHF, Constitutional AI). Equivalent boundaries appear in classical security architectures (reference monitor; policy decision point / policy enforcement point pattern; runtime contract enforcement).
- **Threat source.** Defined in context of all three frameworks (ATT&CK = external human adversary; ATLAS = adversary targeting AI/ML; ATX-1 = the AI agent itself, with explicit acknowledgement that composite scenarios involving external triggers are in scope).
- **Capability and authority.** Capability is technical can-do; authority is architectural may-do.
- **Scope (not exclusionary).** Explicit statement that ATX-1 complements ATT&CK and ATLAS; a production deployment requires layered controls.

AE-6. Clearer demonstration of practical usage; stronger framework comparison.

Reviewer’s concern. “The manuscript would benefit from clearer demonstration of practical usage and stronger comparison with existing frameworks.”

Response. Concur. The original manuscript’s *Use Cases* subsection described hypothetical SIEM integration, compliance mapping, and research benchmarking without walking a concrete example. The revision adds an end-to-end worked example.

Action. A new *Worked Example: Replit Production-Database Deletion* subsection is added inside §INSIGHTS AND NOTES, between *Use Cases* and *Limitations*. It traces one documented production incident through the full ATX-1 pipeline:

1. **Incident description** (AI Incident Database #1152, July 2025).
2. **ATX-1 mapping** to T3001 (Perform Irreversible Destructive Action, RC2+RC3) and T5001 (Report False Task Completion, RC4).
3. **STIX bundle query** with a Python `stix2` code snippet demonstrating SIEM-pipeline integration.
4. **AEGIS mitigation** via the AGP-1 action-reversibility check at the governance boundary.
5. **Adjacent-framework coverage comparison.** ATT&CK T1485 (partial, threat-source mismatch); ATLAS (not applicable, agent is actor not target); OWASP LLM06 (category match, no decomposition); ATX-1 (full coverage with mechanism + mitigation + regulatory crossref + STIX).

This subsection also responds to Reviewer 2 comments R2-3 (a–d) and R2-4c.

Reviewer 1 Comments

R1-1. Severity ratings lack quantitative risk model.

Reviewer’s concern. “Severity ratings (critical/high/medium/low) are based solely on the author’s judgment, lacking a quantitative risk model or statistical validation.”

Response. Same disposition as AE-1: the severity field is removed in v2.3.

Action. See AE-1 above.

R1-2. No evaluation in production or independent third-party testing.

Reviewer’s concern. “There are no evaluation of ATX-1’s effectiveness in production deployments or independent third-party testing.”

Response. Concur. The revision adds three lines of external evidence.

Action. See AE-3 above. Specifically: the Round 1 controlled evaluation (Zenodo DOI 10.5281/zenodo.20159697); fourteen corroborating studies; two production-incident postmortems (EchoLeak, Replit). All are catalogued in the new *External Validation and Corroborating Evidence* subsection.

R1-3. “Agentic AI”, “governance boundary”, “threat source” lack precise definitions.

Reviewer’s concern. Same wording as the question.

Response. Concur.

Action. See AE-5 above. The new *Definitions* subsection provides formal definitions for all three terms.

Reviewer 2 Comments

R2-1. Empirical foundation is too single; case-to-technique abstraction questionable.

Reviewer’s concern. “The manuscript repeatedly emphasizes that all 20 techniques are derived from the study of Agents of Chaos, and is supplemented by a small number of other recent papers as ‘corroboration’. This means that the experience sources of ATX-1 are actually highly concentrated... More importantly, the author did not fully explain why 11 case studies are sufficient to abstract 20 techniques, whether there is overfitting in the abstraction from cases to taxonomy, and whether there are independent sources of data to test the coverage or discrimination of taxonomy.”

Response. This concern decomposes into three sub-questions, each addressed in the revision:

- (a) *Why are 11 case studies sufficient to abstract 20 techniques?* The new *Construction Reproducibility* subsection documents the case-to-technique abstraction criteria explicitly. The 11-cases-to-20-techniques ratio arises because some cases (e.g., AoC CS#1) surface multiple distinct mechanisms, and some techniques aggregate multiple cases on a common mechanism. The criteria for both directions are now in writing.
- (b) *Is there overfitting?* The new *External Validation* subsection establishes that the taxonomy is independently observable outside the AoC dataset. Eight of ten v2.3 tactics were reproduced in a controlled multi-agent evaluation (Round 1) that the authors did not have access to when constructing the v1.0 taxonomy. Cemri et al.’s independent MAST taxonomy (200+ multi-agent traces, NeurIPS 2025) converges on overlapping failure categories.
- (c) *Independent sources to test coverage?* The corroborating-studies coverage matrix cites fourteen independent studies; each tactic has at least three independent observation sources.

Action. Reproducibility subsection + External Validation subsection. The bibliography expansion (15 → 29 entries) reflects the broadened empirical base.

R2-2. Taxonomy construction process lacks reproducibility.

Reviewer’s concern. “What are the coding rules for cases? How can a failure mode be divided into techniques? What are the criteria for merging multiple cases into one technique? How to determine the tactic boundary?”

Response. Concur. Each of these four questions is addressed explicitly in the new *Construction Reproducibility* subsection.

Action.

- *Coding rules for cases.* RC1–RC5 each carry an explicit coding condition (when an observed failure should be coded with that root cause). Multiple root causes per technique are permitted.
- *Failure mode → techniques.* Decomposition criteria: mechanism, mitigation, threat surface. Different on any of the three → separate techniques.
- *Merging criteria.* Mechanism, mitigation, and threat surface all aligning → collapse into a single technique.
- *Tactic boundary.* Three-factor priority: agent’s effective goal, architectural layer affected, dominant mitigation pattern.

The subsection also includes an end-to-end processing flow specifying inputs and outputs at each of the four stages.

R2-3. Use cases are potential, not empirical; need concrete examples and framework comparison.

Reviewer’s concern. “[SIEM import, compliance mapping, benchmarks] are more potential use cases than empirical demonstrations. If a small example could be added, such as how to use STIX bundle to query in a certain threat Intel pipeline; how to map a real agent incident to one or more techniques; how to compare the coverage differences between ATX-1 and ATT&CK/ATLAS/OWASP in the same case; it will significantly enhance the persuasiveness of the paper.”

Response. Concur. The new *Worked Example* subsection addresses all four of the sub-requests in a single concrete walkthrough.

Action. See AE-6 above. The Worked Example covers:

- STIX bundle query in a threat-intel pipeline (Python `stix2` code snippet, SIEM-import path).
- Real-incident-to-technique mapping (Replit incident → T3001 + T5001).
- Coverage comparison ATX-1 vs. ATT&CK T1485 vs. ATLAS vs. OWASP LLM06 on the same case (bulleted comparison).
- Specific ATX-1 vs. OWASP differences (R2-4c below).

R2-4. Terminology boundaries; endogenous-vs-exogenous framing; OWASP comparison vague.

Reviewer’s concern. “The boundaries of terminology need to be more rigorous. In the article, the phrases ‘AI agent is the threat source’ and ‘not through compromise, but through structural capability without authority’ are strongly expressed. However, in reality, many risk scenarios involve composite factors such as prompt injection, tool misuse, and cross agent trust failure. It is recommended to avoid overly dividing the endogenous risks of agents from external attacks. The difference description with OWASP is slightly vague.”

Response. Concur on all three points.

Action.

- *Strong threat-source language softened.* The Background paragraph that previously stated “the AI agent itself is the threat source” is rewritten to “the agent-resident failure surface—the conditions under which an agent’s own action path produces destructive outcomes regardless of whether the immediate trigger is internal (emergent under permissive conditions) or external (e.g., indirect prompt injection that flows through the agent’s reasoning into the action layer).” A second paragraph that used the same framing is rewritten similarly. Figure 1’s caption is updated to match.
- *Endogenous-vs-exogenous division avoided.* The new *Scope (not exclusionary)* paragraph in the Definitions subsection states explicitly: “A production agent deployment will routinely encounter composite risk scenarios that combine adversarial inputs with structural agent vulnerabilities; a complete security posture requires controls drawn from ATX-1 (agent-resident failure modes), ATT&CK (human adversaries against the supporting infrastructure), and ATLAS (adversaries against the agent’s model or pipeline). Practitioners should treat the three taxonomies as a layered defense, not as competing accounts.”
- *OWASP difference clarified.* The Worked Example subsection includes a specific comparison: “OWASP LLM06 (Excessive Agency)... is a single high-level risk; it does not decompose to a specific failure mechanism, does not specify an architectural mitigation, and does not publish a STIX-encoded artifact for SIEM ingestion. Coverage: matched at the category level only.” The same example shows ATX-1 providing specific mechanism, mitigation, and STIX integration.

R2 Additional Questions: technical-quality and replication-detail concerns.

Reviewer’s concern (technical quality). “Lack of external validation, expert review, consistency testing, or comparative benchmark analysis.”

Response. External validation is now established in the new *External Validation and Corroborating Evidence* subsection (see AE-3 above). Cross-framework comparison is established in the Worked Example. The Microsoft AI Red Team’s *Taxonomy of Failure Modes in Agentic AI Systems* (April 2025) is now cited as a parallel independent taxonomy that converges on overlapping categories. MITRE ATLAS v5.4.0 added fourteen agentic techniques in late 2025–early 2026 that

map directly to ATX-1 entries.

Reviewer’s concern (replication). “Lacks complete processing flow, judgment criteria, and decision rules from the original case to the final technique/action/root cause.”

Response. Addressed in the new *Construction Reproducibility* subsection. The complete processing flow is documented, with explicit decision rules at each stage. See AE-2 above.

Summary of Changes

Reviewer concern	Manuscript change
EiC: TM in title	Removed via tracked-changes deletion
AE-1, R1-1: severity ratings	severity field removed in v2.3; new <i>Severity Removed in v2.3</i> subsection
AE-2, R2-2 (4 sub-questions), R2-Q-replication	New <i>Construction Reproducibility</i> subsection
AE-3, AE-4, R1-2, R2-1 (3 sub-questions), R2-Q-tech	New <i>External Validation and Corroborating Evidence</i> subsection; bibliography expanded 15 → 35 entries (20 new); Limitations rewritten
AE-5, R1-3	New <i>Definitions</i> subsection (5 formal definitions)
AE-6, R2-3 (4 sub-questions), R2-4c	New <i>Worked Example: Replit Production-Database Deletion</i> subsection
R2-4a, R2-4b	Background framing softened; <i>Scope (not exclusionary)</i> paragraph added in Definitions

Numerical claims throughout the manuscript are updated from v1.0 (9 tactics, 20 techniques, 4 root causes, 104 STIX objects) to v2.3 (10 tactics, 29 techniques with 29 sub-techniques, 5 root causes, 204 STIX objects). The DATA DOI/PID is updated from the v1.0 IEEE DataPort DOI to the v2.3 Zenodo DOI ([10.5281/zenodo.20171712](https://doi.org/10.5281/zenodo.20171712)); the v2.3 IEEE DataPort deposit is forthcoming. v1.0 remains frozen at its original DOI for reproducibility of the reviewed record.

We thank the reviewers and editors for the depth of the review, which has substantially strengthened the manuscript. We look forward to your decision.

License. This document is released under the Creative Commons Attribution 4.0 International License (CC BY 4.0).